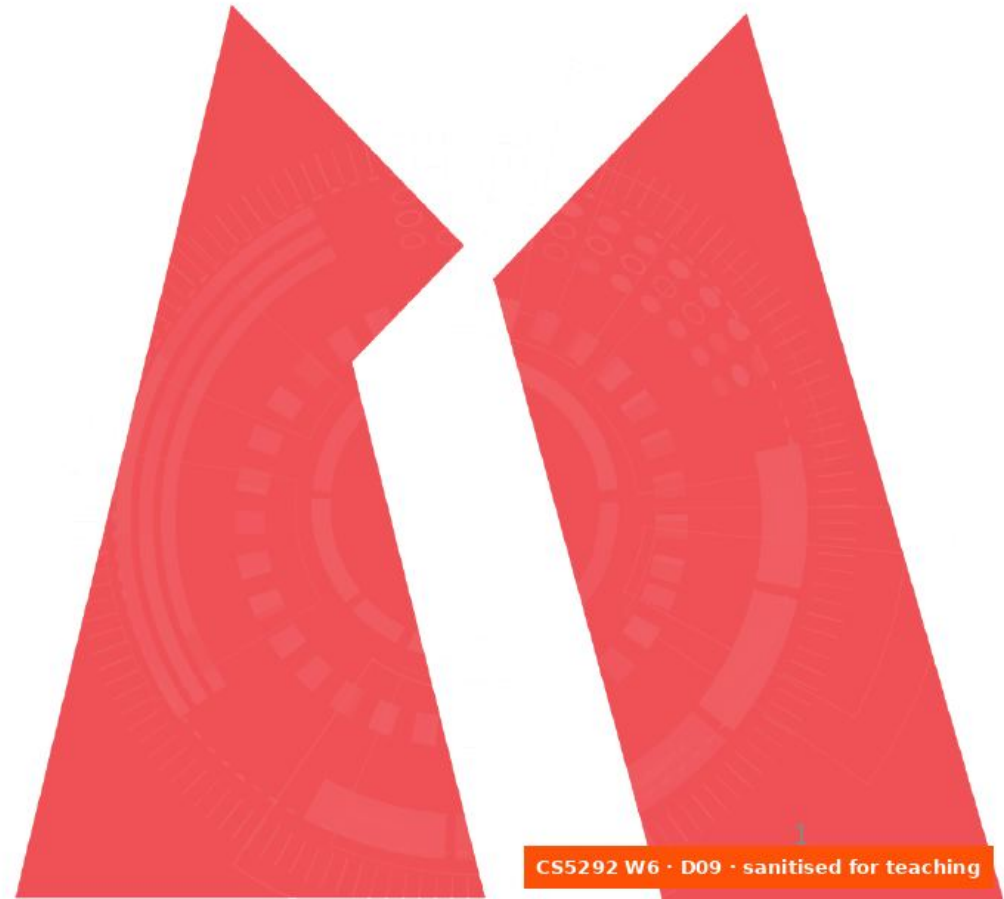
CYBER SECURITY Steering Committee

(CSSC 29-09-2025)



AGENDA

	AGENDA	Time Allocations	PRESENTER(S)
01	Introduction & clarification on the pre-read	3 Minutes	Chair
02	Update on Previous Action Items	5 Minutes	P-A
03	Terms of Reference (TOR)	10 Minutes	Chair
04	Cybersecurity Performance Metrics	5 Minutes	P-A
05	Emerging Threat Overview	15 Minutes	P-A
06	Summary of Incidents	10 Minutes	P-A
07	Journey through Maturity	10 Minutes	P-C/P-B/P-A
08	Data Protection and Cyber Risk Grid	10 Minutes	P-B/P-A
09	Open Discussion and Q&A	10 Minutes	

XYZ | XYZ Only

CS5292 W6 · D09 · sanitised for teaching

Update on Previous Action Items



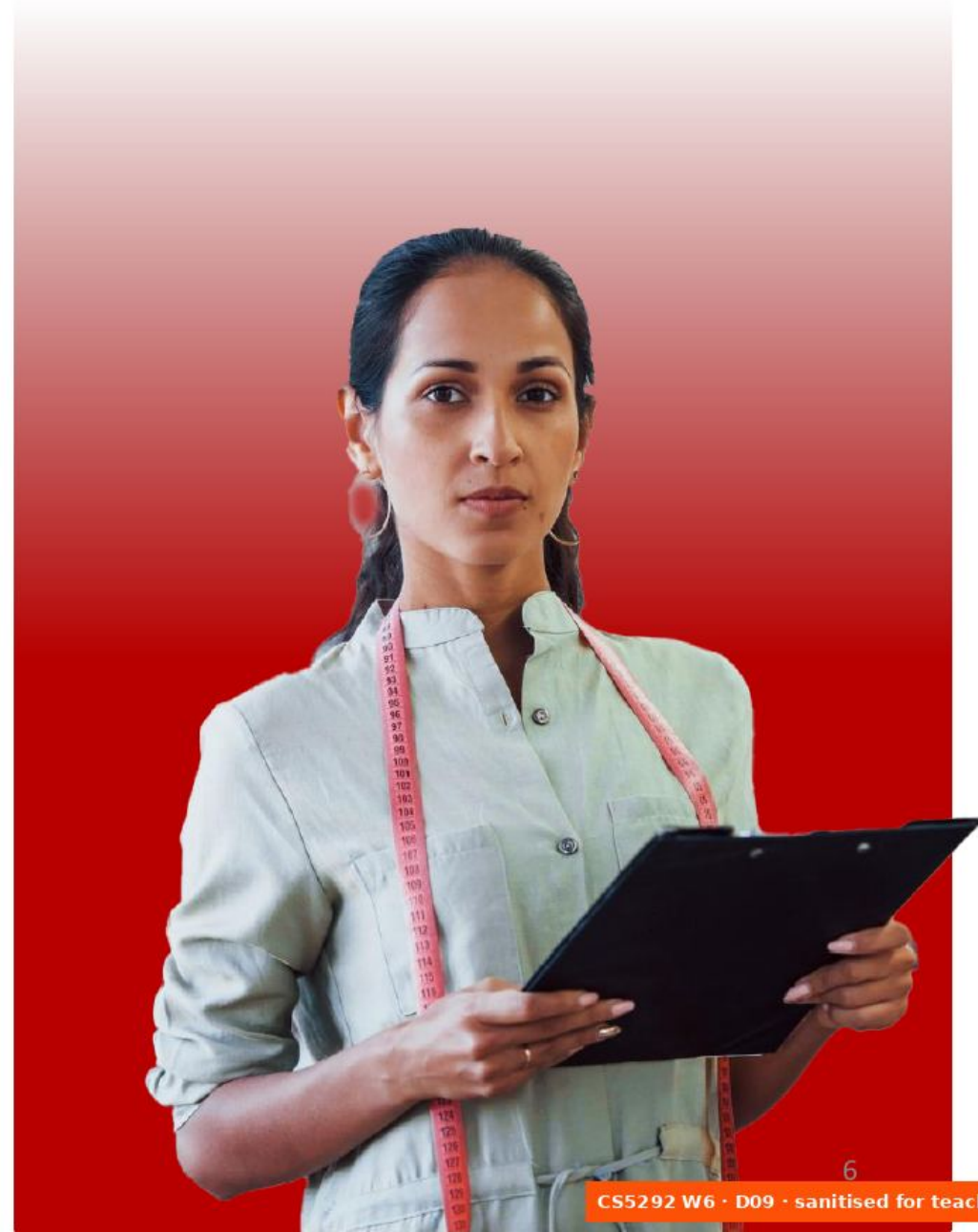
XYZ | XYZ Only

Previous Action Items

Actions Discussed	Responsible	Due	Actions Taken	Status
Socialize the AI policy and share with Group Legal	P-A	**19 June 2025**	**AI Policy shared**	**Completed**
SLA times to be elaborated and reported	P-A		**Incident response times are reported for all categories**	**Completed**

XYZ | XYZ Only

Terms of Reference (TOR)



XYZ | XYZ Only

Terms of Reference (ToR)

PURPOSE

To ensure initiatives taken to **minimize technology-related enterprise risks**, including cyber security, are governed and mitigated. Group Technology Risk Committee **(GTRC) is a subcommittee of** Group **board** as mandated.

SCOPE OF GTRC

Scope of the XYZ Technology Risk Committee is to consider the protection of digital information, Operational Technologies, and all technology-related enterprise risks within XYZ Group. The scope will be reviewed annually.



AUTHORITY

The Group Technology Risk Committee is the ultimate authority for all technology risk management decisions across the XYZ group.

The decisions and policies implemented by the GTRC will apply to XYZ, including all its subsidiaries where XYZ Technology Services provides IT services.

The GTRC shall make recommendations for CAPEX and investment related to technology risk to the Board, which will follow the standard CAPEX approval process.

RESPONSIBILITIES OF THE COMMITTEE

Governance & Oversight
Provides independent oversight of technology risk and defines the organization's risk appetite on behalf of the Group Board.

Policy & Strategy
Establishes guiding principles, policies, and long-term strategies for IT and Operational Technology risk management.

Compliance & Monitoring
Ensures adherence to cyber and data protection laws, reviews risk indicators, and monitors control effectiveness.

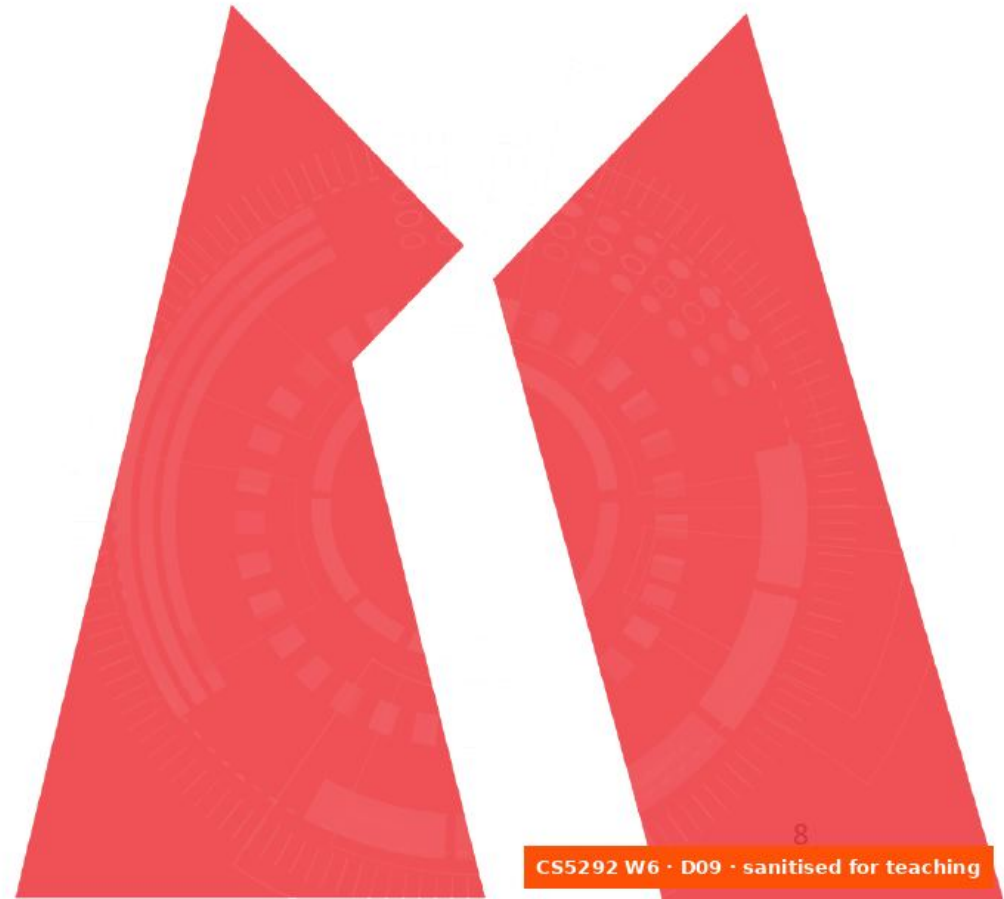
Incident & Dispute Management
Facilitates resolution of policy disputes and escalates incidents impacting confidentiality, integrity, and availability of systems.

Leadership & Accountability
Assigns key roles, guides resource allocation, and evaluates performance of risk mitigation initiatives.

XYZ | XYZ Only

Cyber Security

Performance Matrics



XYZ | XYZ Only

Cybersecurity KPIs Q3 2025

SOC Detections Q2 2025	Priority	Q2 (2025)	Q3 (2025)	SLA	
Mean Time to Respond (by MSSP)	P1	-	-	15 mins	
	P2	-	-	30 mins	⬇
	P3	48 mins	-	60 mins	
	P4	54 mins	48 mins	120 mins	
Mean Time to Respond (by XYZ SOC)	P1	-	-	15 mins	
	P2	-	-	30 mins	⬇
	P3	22 mins	-	45 mins	
	P4	390 mins	352 mins	60 mins	
Mean Time to Resolve (MTTR)	P1	-	-	4 Hrs	
	P2	-	-	24 Hrs	⬇
	P3	3.9 Days	-	5 Days	
	P4	1.6 Days	1.5 Days	14 Days	

* From 2025, Sources of Incidents: SIEM, EDR & TI

* The industry standard for **Mean Time to Respond** in cybersecurity benchmark is around 24 hour

* Average Organizations typically have a Mean **Time to Resolve** ranging from 24 to 72 hours.



Patching Compliance:

Windows Device Compliance	N	N-1	End of Support
End Device	82.80%	17.62%	0.46%
Servers		99.00%	11.0%

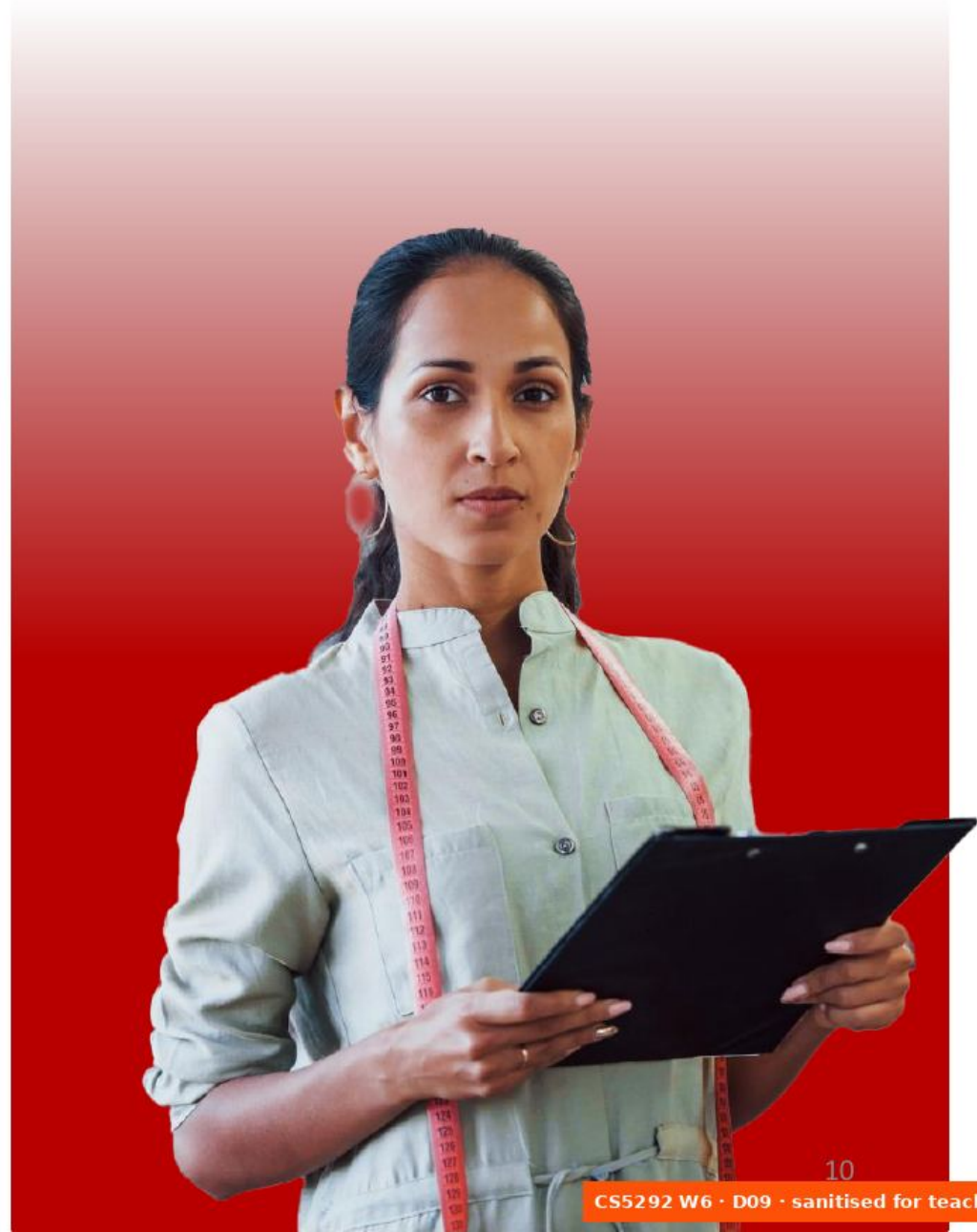
Detection Count:

Quarter	P1	P2	P3	P4
Q2 (2025)	-	-	2	1667
Q3 (2025)	-	-	-	1260

XYZ | XYZ Only

CS5292 W6 · D09 · sanitised for teaching

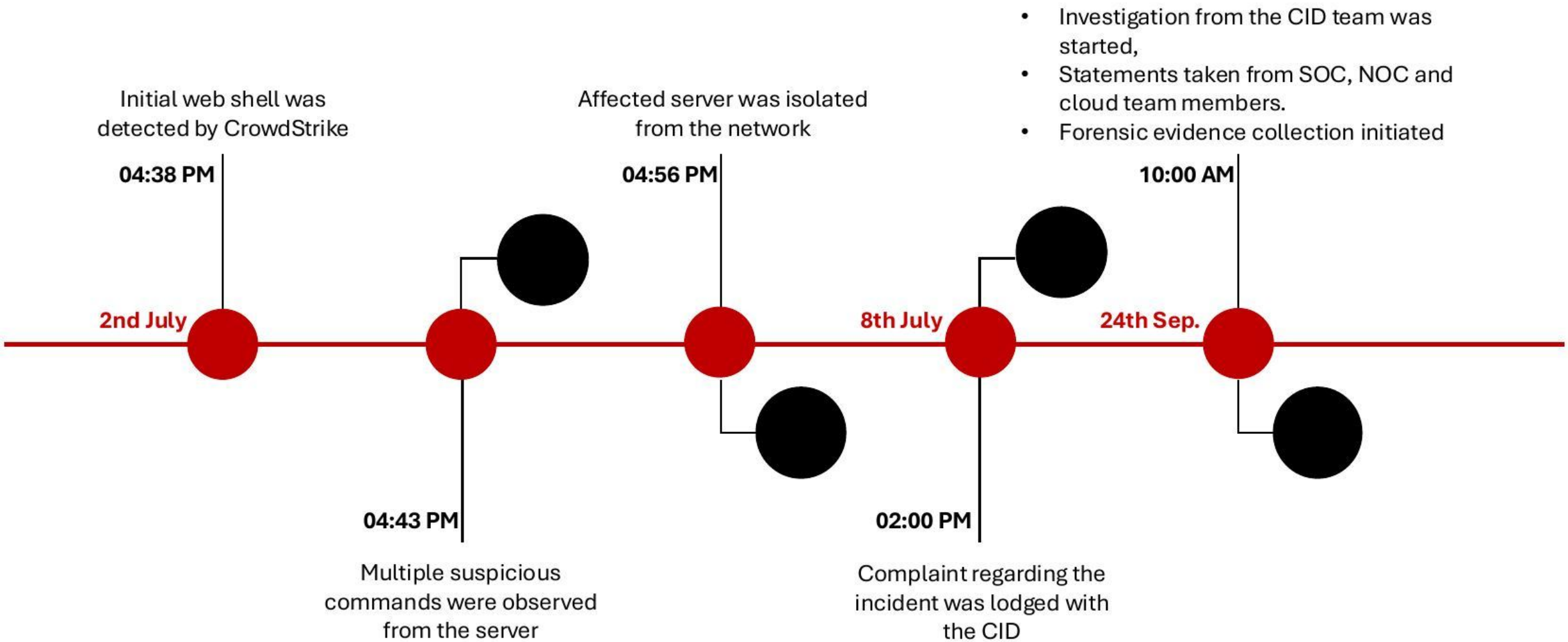
Summary of Incidents



XYZ | XYZ Only

Devapp3 Incident

Law enforcement involved



xyz | xyz Only

Cyber Security Emerging Threat Overview



XYZ | XYZ Only

Emerging Threat Overview

The Rise of GenAI-Driven Cyber Threats (Enterprise Risk 8)



Used to amplify social engineering tactics and accelerate sophisticated exploit development.
Functions as both a target and a tool for malicious activity.

Organizational Response

- Finalized the AI Policy to address GenAI-related risks.
- Initiated implementation of a Cloud Access Security Broker (CASB) platform this quarter.
- Engaged consultants to support technical security architecture planning.

Recent Attacks

- AsyncRAT Malicious Code Development
- ShadowLeak zero-click flaw in ChatGPT

SaaS Intrusions Surge with Cloud-Conscious Attacks (Enterprise Risk 8)



Threat actors increasingly target cloud-based SaaS platforms to:

- Access sensitive data.
- Move laterally within enterprise networks.

Shift from on-premises to cloud services has led adversaries to evolve their tactics.

Organizational Response

- Launch of SaaS Security Posture Management (SSPM) project planned for Q2 2026.

Recent Attacks

- SCATTERED SPIDER: Used a compromised inbox to send 700,000+ phishing SMS messages.
- Atlas Lion: Leveraged SaaS apps in gift card fraud campaigns.

Advanced Vulnerability Exploitation Methodologies(Cyber Risk 6)



Threat actors continue to target unmanaged, internet-facing hosts, especially network appliances.
These are commonly used as initial access points into enterprise environments.

Organizational Response

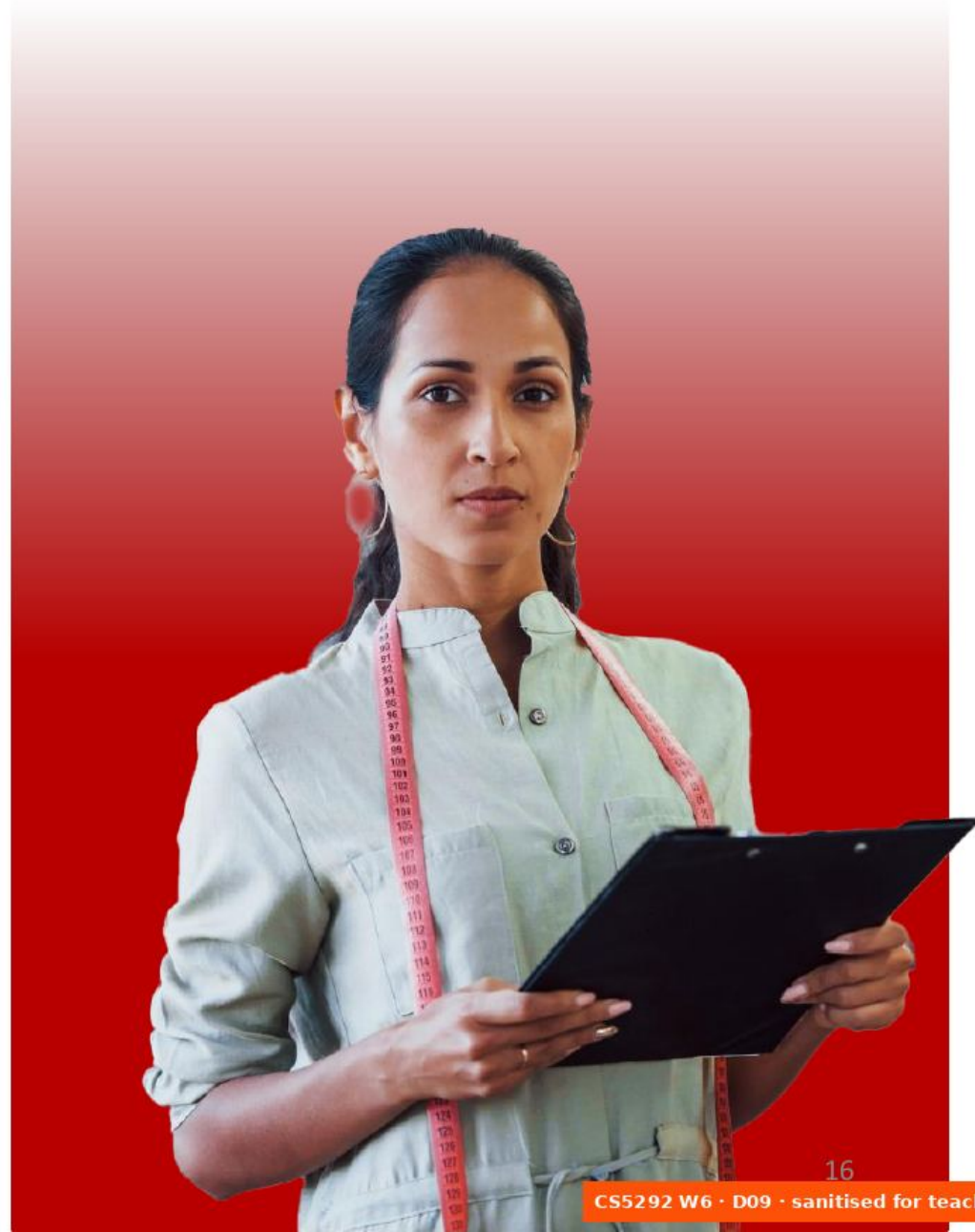
Vulnerability Fixes with Upgrades Project
Security Hardening and Patch Management Automation

Recent Attacks

- SAP vulnerability CVE-2025-31324

XYZ | XYZ Only

Journey Through Maturity



XYZ | XYZ Only

XYZ AI Usage Policy

Governance Accountability

Head of IT Security oversees all AI initiatives, approvals, risk assessments, and incident response.

Data Usage Controls

Only anonymized, consent-based, and secure data allowed; sensitive or unauthorized data strictly prohibited.

Third-Party AI Services

Require formal approval and evaluation for security, compliance, ethics, and vendor reliability.



Responsible AI Use

Fairness, accountability, explainability, safety, reliability, and privacy guide all AI activities.

Permitted Applications

AI may be used for business optimization, analytics, customer service, cybersecurity, and R&D.

Prohibited Applications

No use for surveillance, discrimination, misinformation, unauthorized data processing, or harmful systems.

Microsoft Copilot, Azure OpenAI, Azure AI Vision, Azure AI foundry , Azure AI Search, Azure Cognitive Search, DALL·E, Midjourney, Managed Milvus, Databricks hosted models, Stable Diffusion, Databricks Delta + Vector are AI solutions approved to be used within XYZ

XYZ | XYZ Only

Supplier Security Assessment

Assessment Coverage Summary:
Iinitial 3rd-party assessment covered 29 vendors (4 were JVs or our SBUs, excluded). Assessment conducted for 24 vendors -16 submitted responses, 8 pending.

Next Steps to do:

- Recommendations to be shared with suppliers in High and Medium, continues follow-ups and annual assessment
- NDA or confidentiality clauses with suppliers to be ensured via legal team for smooth document collection and reviewing
- Firsthand verification - Quarterly one on-site visiting supplier risk assessment.
- Education and training program for low scoring suppliers



Pending Suppliers	Remarks	
One[redacted]	No Response	Considered High risk
	Demanding NDA	

Attack Surface Reduction

Decommission	**8 Sites decommissioned**
Restrictions	**180 Azure Web Applications under review** **129 Azure Apps/Web sites access restricted**
Applications	**1675 applications are identified blocking**

1661 Unclassified Applications	2 Dev/Productivity Tools
7 Business Applications	5 Utility/Security Applications

As part of the Attack Surface Reduction initiative, several outdated sites have been decommissioned, Azure web applications are undergoing review, a select group has been restricted, and over 1600 applications have been disabled. This will strengthen the cybersecurity posture by minimizing exposure to threats, enhancing compliance with security standards, and reducing the overall digital risk footprint.

KEY ENTERPRISE RISK MANAGEMENT – 2026

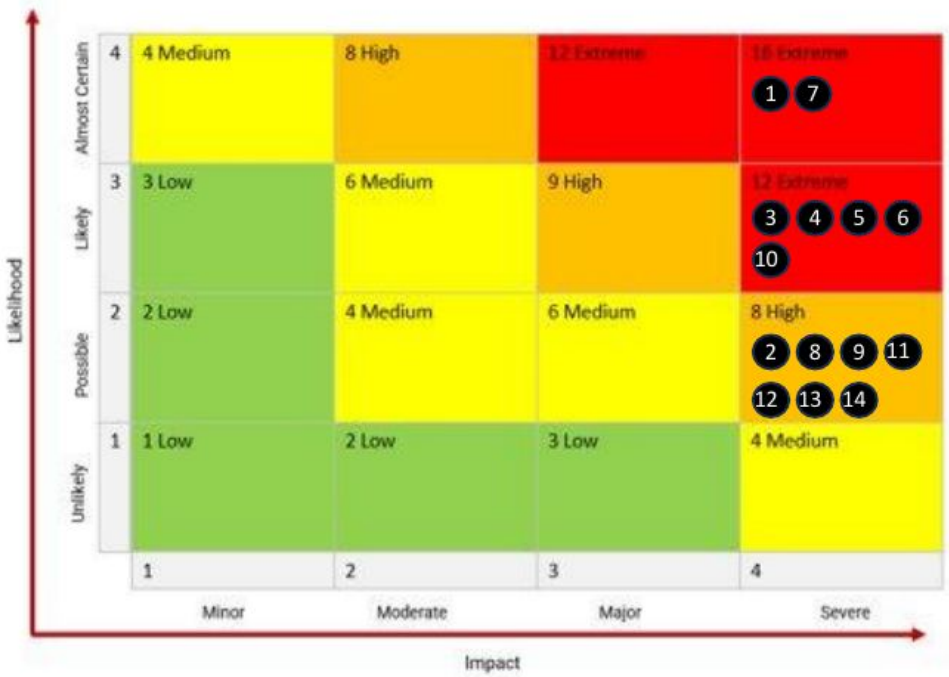
Increase	Static	Decrease

1 Information & Cyber Security

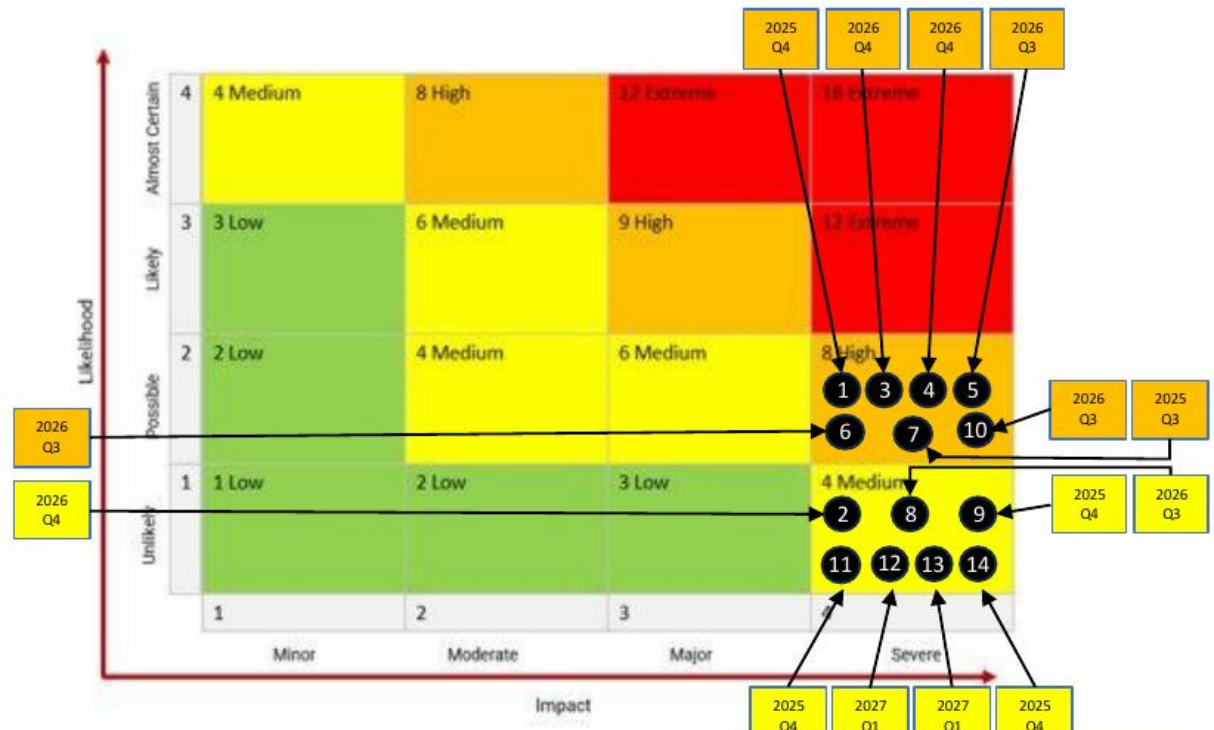
Disruptions for the applications, services due to cyber security incident caused by:

- unpatched vulnerabilities
- lack of employee awareness
- EOL hardware and software
- supply chain vulnerabilities
- non-standard governance
- shadow IT,
- lack of adherence to standard procedures

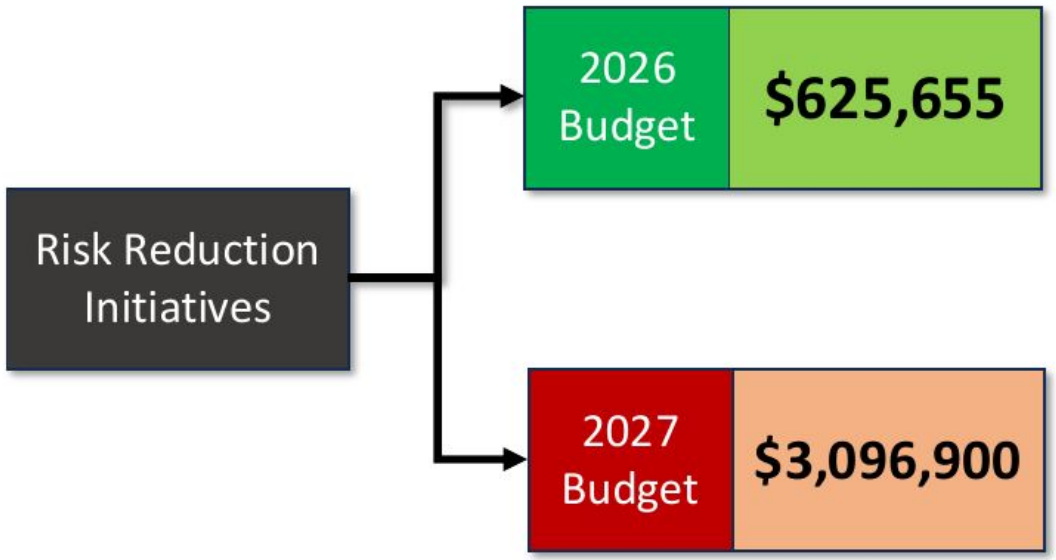
Current



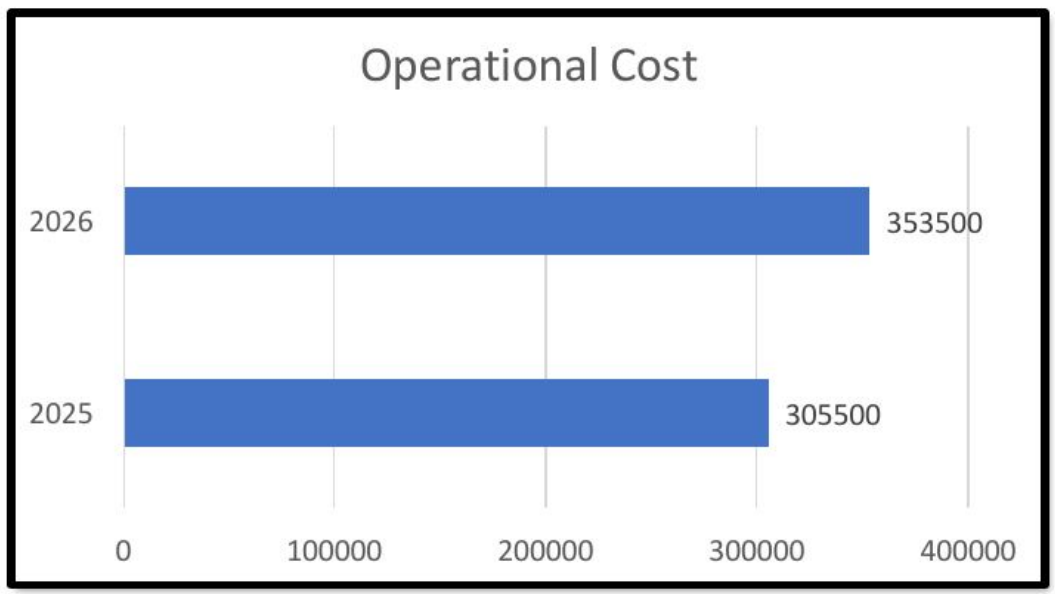
Projection



Security Investments Summary







Cost of Initiatives not budgeted for 2026	$1,372,061
Cost of Initiatives Influenced, for SBUs	$8,583,846

XYZ | XYZ Only

Cyber Security Operational Cost

Operational Cost	Budget Category	Budget 2026
Cloud security - Posture Management (Palo Alto)	Software Maintenance & Development	45,000
Vulnerability Management program & tooling (Qualys)	Software Maintenance & Development	25,000
API Security Gateway	Software Maintenance & Development	50,000
SocRadar License Subscription for Dark web monitoring	Software Maintenance & Development	37,000
Critical application external review	Professional Fees	15,000
Manage Security Service (Security Operations)	Professional Fees	71,000
Application development security testing (Checkmarx)	Professional Fees	27,500
Cyber Security (Red team) external staff pay	Professional Fees	18,000
Red teaming	Professional Fees	65,000
		353,500

Security Solution	Budget 2025	Budget 2026	Variance
Crowdstrike	295,297	446,605	151,308
Mimecast	190,064	260,000	69,936
Sentinel SIEM	169,000	169,000	-
Zscaler	280,000	260,000	(20,000)
Total	**934,361**	**1,135,605**	**201,244**

Security Initiatives

Total Impact: 10,450,000

Influenced, Reflected in SBU budget | Not budget for 2026

Risk	Initiative/Project	Expected Change of Risk Level	Year	Budget 2026	Budget 2027	Implementation Cost
Risk of an attack by a cyber criminal due to lack of employee awareness.	Risky user continuous awareness training	16. Extreme (4x4) to 8. High (4x2)	2026 Q1	11,450	102,000	113,450
Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices	On-prem Datacenter EOL HW Replacement (Rental/Cloud)	8. High (4x2) to 4. Medium (4x1)	2026 Q4	380,070		380,070
	Virtual desktop Infrastructure (Thin Client)			26,380	1,780,000	1,806,380
	Plant Network EOL Switch Replacements			1,240,000		
Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices	IoT device inventory creation (internal effort)	12. Extreme (4x3) to 8. High (4x2)	2026 Q4	-	-	-
	Device Replacement (Laptop, Desktops 4995, TABs 4000)			7,343,846		
Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZ Sub-B USA / Sub-C	Sub-B Site Standardization	12. Extreme (4x3) to 8. High (4x2)	2026 Q4	102,250	270,000	372,750
	Sub- Domain Migration (Plan finished 2025)			-	-	-
	Sub-C Domain Migration & Network Re finement (Plan finished 2025)			-	-	-
Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2	Isolation through network and access (Internal effort)	12. Extreme (4x3) to 8. High (4x2)	2026 Q3	-	-	-

XYZ | XYZ Only

Security Initiatives

Total Impact: 10,450,000

Influenced, Reflected in SBU budget | Not budget for 2026

Risk	Initiative/Project	Change of Risk Level	Year	Budget 2026	Budget 2027	Implementation Cost
Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system	Security Vulnerability Fixes with upgrades	12. Extreme (4x3) to 8. High (4x2)	2026 Q3	46,900	79,000	125,900
	Non SAP Application version upgrades and DB upgrades			10,000	15,000	25,000
	Application Modernisation (Infra) - Non SAP (40+ applications)			668,927		668,927
Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack	Supplier risk assessment and monitoring	16. Extreme (4x4) to 8. High (4x2)	2025 Q3	12,900	20,000	32,900
Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server /Laptop / API Connection	Migrate all XYZ domains to centralized service along with SSL certificates.	8. High (4x2) to 4. Medium (4x1)	2026 Q3	51,450	250,000	301,450
	Application Migration to Landing Zone (50+ applications in Non-LZ)			118,997		118,997
	MAM (Mobile Application Management)			85,070		85,070
Risk of a cyber security incident as a result of Shadow IT	Cloud Access Security Broker platform Implementation	8. High (4x2) to 4. Medium (4x1)	2025 Q4	23,480	180,000	203,480
Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.	DevOps Workflow Automation	12. Extreme (4x3) to 8. High (4x2)	2026 Q3	118,997		118,997
	Firewall Rules Management & Automation Implementation			101,380	70,000	171,380

Security Initiatives

Total Impact: 10,450,000

Influenced, Reflected in SBU budget | Not budget for 2026

Risk	Initiative/Project	Change of Risk Level	Year	Budget 2026	Budget 2027	Implementation Cost
Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy	ServiceNow Implementation	8. High (4x2) to 4. Medium (4x1)	2025 Q4			500,000
Risk of a Cyber Security Incident as a result of a malware infection	Security Hardening & Patch management automation Implementation	8. High (4x2) to 4. Medium (4x1)	2027 Q1	27,250	40,000	67,250
	Network Micro segmentation initiative			181,315	260,000	441,315
Risk of Cyber Security Incident as a result of activities of State Sponsored and/or organized crime cyber criminals /cyber terrorists targeting XYZHoldings	Network Micro segmentation initiative.	8. High (4x2) to 4. Medium (4x1)	2027 Q1	-	-	-
	Enable passwordless authentication				618,997	618,997
Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZTechnology Services.	Governance and Risk mitigation around single platform	8. High (4x2) to 4. Medium (4x1)	2025 Q4	30,900	30,900	61,800

XYZ | XYZ Only

Device Compliance

CrowdStrike (CS) Coverage 99.87%

CS Coverage	Count
Covered	15535
Not Covered	19

Intune Deployment Issue – 10

Not Installed - 9

ZScaler (ZS) Coverage 99.18%

ZS Coverage	Count
Covered	15428
Not Covered	126

Subic is still not under XYZ domain, so Zscaler cannot be used in those devices. – 111

Not Installed – 12

Intune deployment Issue - 3

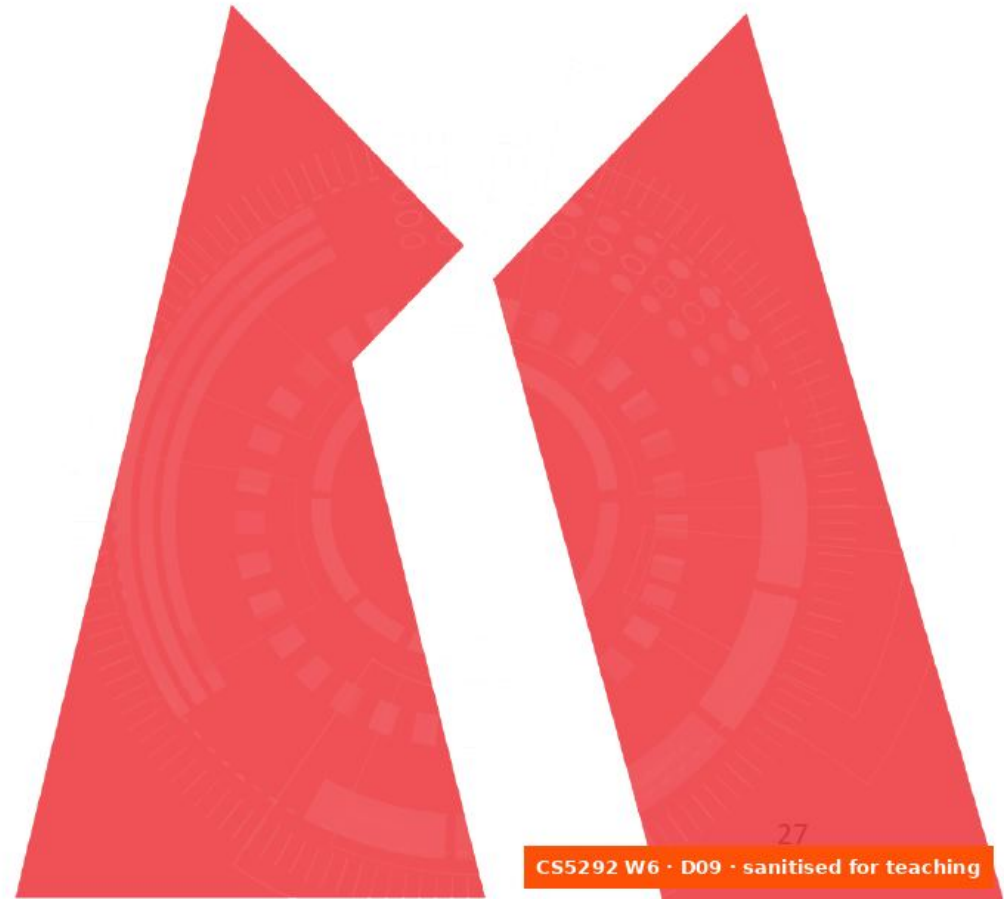
Outdated OS

OS	Count
Microsoft Windows 8.1	12
Microsoft Windows 7	1
Linux	29

Qualys Coverage 100%

Qualys Coverage	Count
Covered	770

Data Protection and Cyber Risk Grid



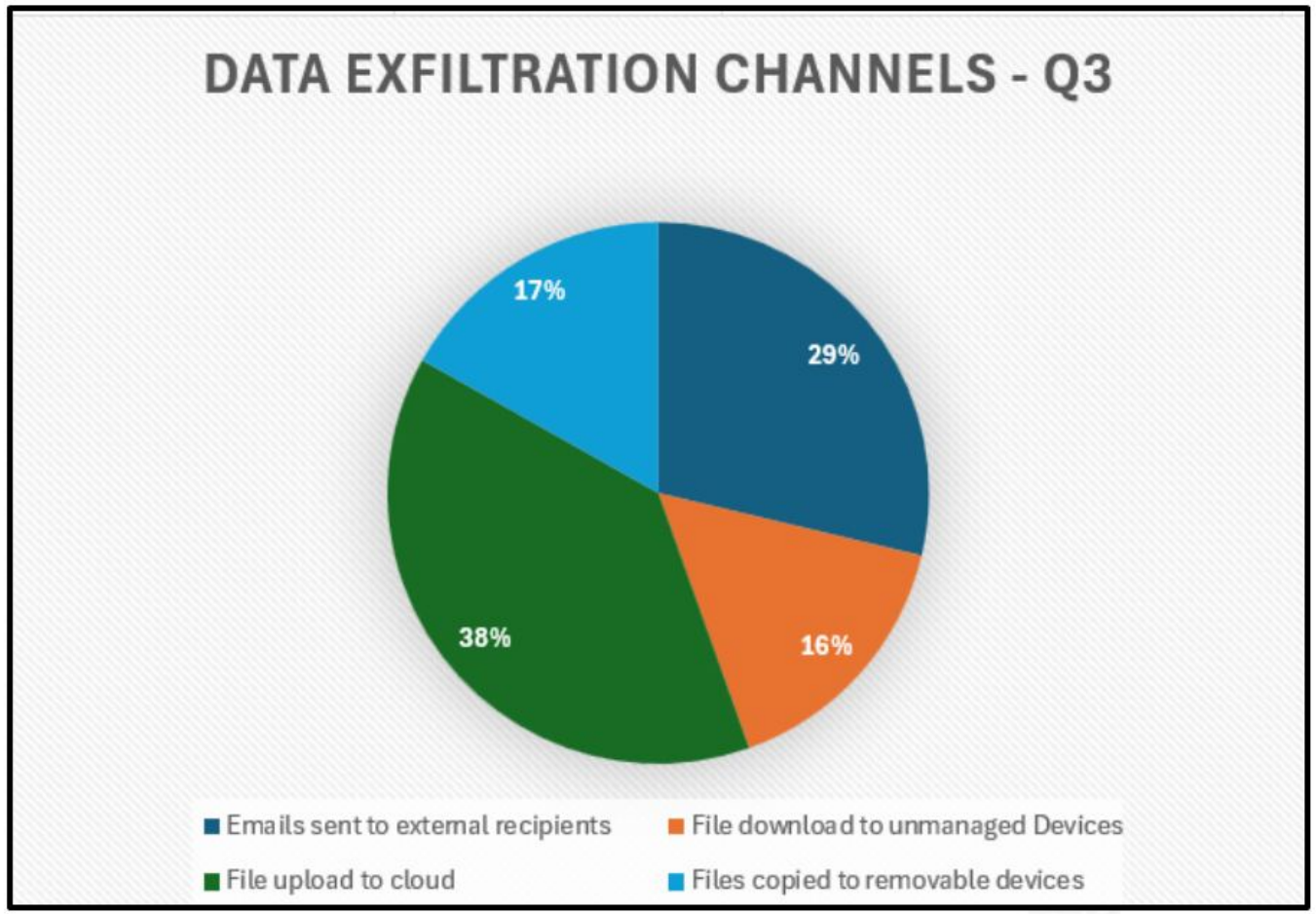
XYZ | XYZ Only

DLP Statistics

Critical Alerts Investigated in Q3 2025

Status	#
Closed	61
Inquiry in progress*	*32
HR/Legal escalation	9
Total	102

*Open incidents are pending user or line manager response



Highlights

- Upload block for 40 domains, including AI-related sites.
- Enable override feature for 12 domains, including Canva and major universities.



XYZ | XYZ Only

CS5292 W6 · D09 · sanitised for teaching

Vulnerabilities in Core Systems

As of Report Generated on 9/24/2025

Application	Critical - Q2	Critical - Q3	High - Q2	High - Q3	Percentage
SAP Unit-3	26	20	36	28	-23%
SAP Unit-2	63	72	138	142	+6%
SAP Unit-4	15	22	16	26	+55%
SAP Unit-1	13	20	17	27	+57%
Unit-5 SAP	3	5	7	12	+70%
Shopfloor	36	48	72	89	+27%
Idea PLM	5	7	20	35	+68%
GSD	5	7	57	59	+6%
Bank Intergration	19	29	34	53	+55%
Ruber	14	22	25	33	+41%
Non SAP - Production App DBs	4	4	13	15	+12%
Fastreact	61	34	223	207	-15%
Darwin	4	17	62	51	+3%
ECC Cloud connector	1	2	26	22	-11%
KoFax	6	15	35	59	+80%
E Transport	2	7	8	10	+70%
Unit-2 Dye system	0	0	15	13	-13%

XYZ | XYZ Only

KEY ENTERPRISE RISK MANAGEMENT – 2026

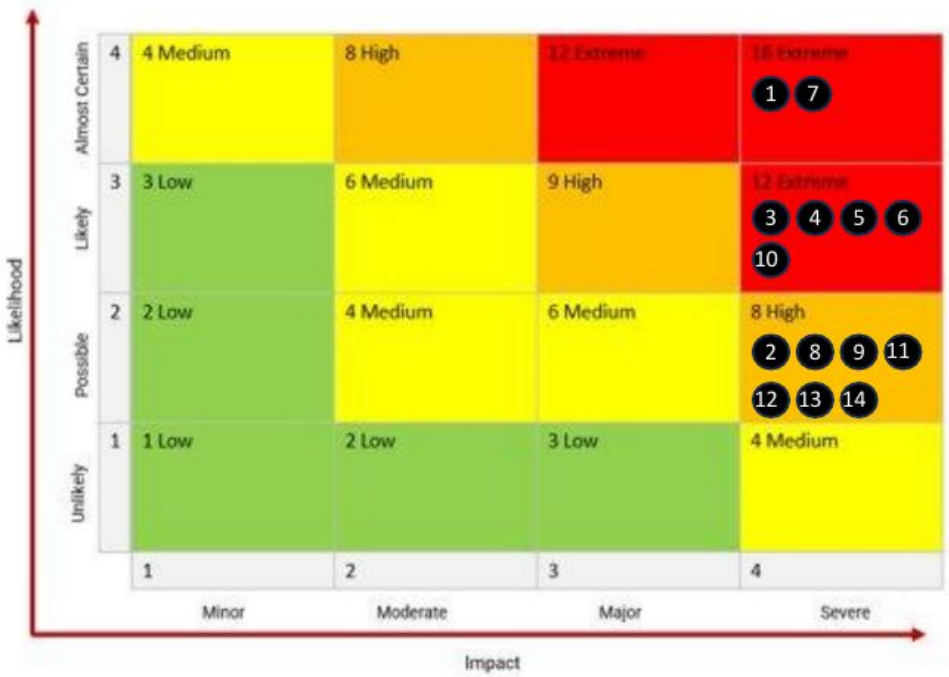
Increase	Static	Decrease

1 Information & Cyber Security

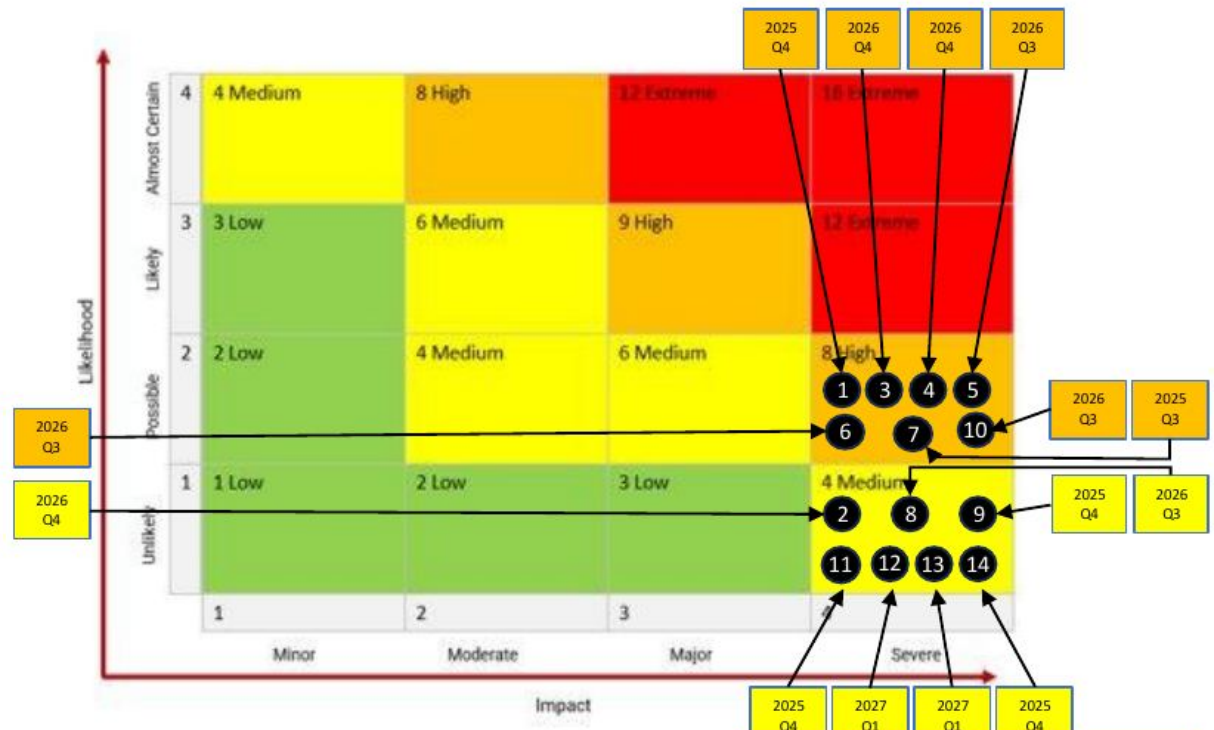
Disruptions for the applications, services due to cyber security incident caused by:

- unpatched vulnerabilities
- lack of employee awareness
- EOL hardware and software
- supply chain vulnerabilities
- non-standard governance
- shadow IT,
- lack of adherence to standard procedures

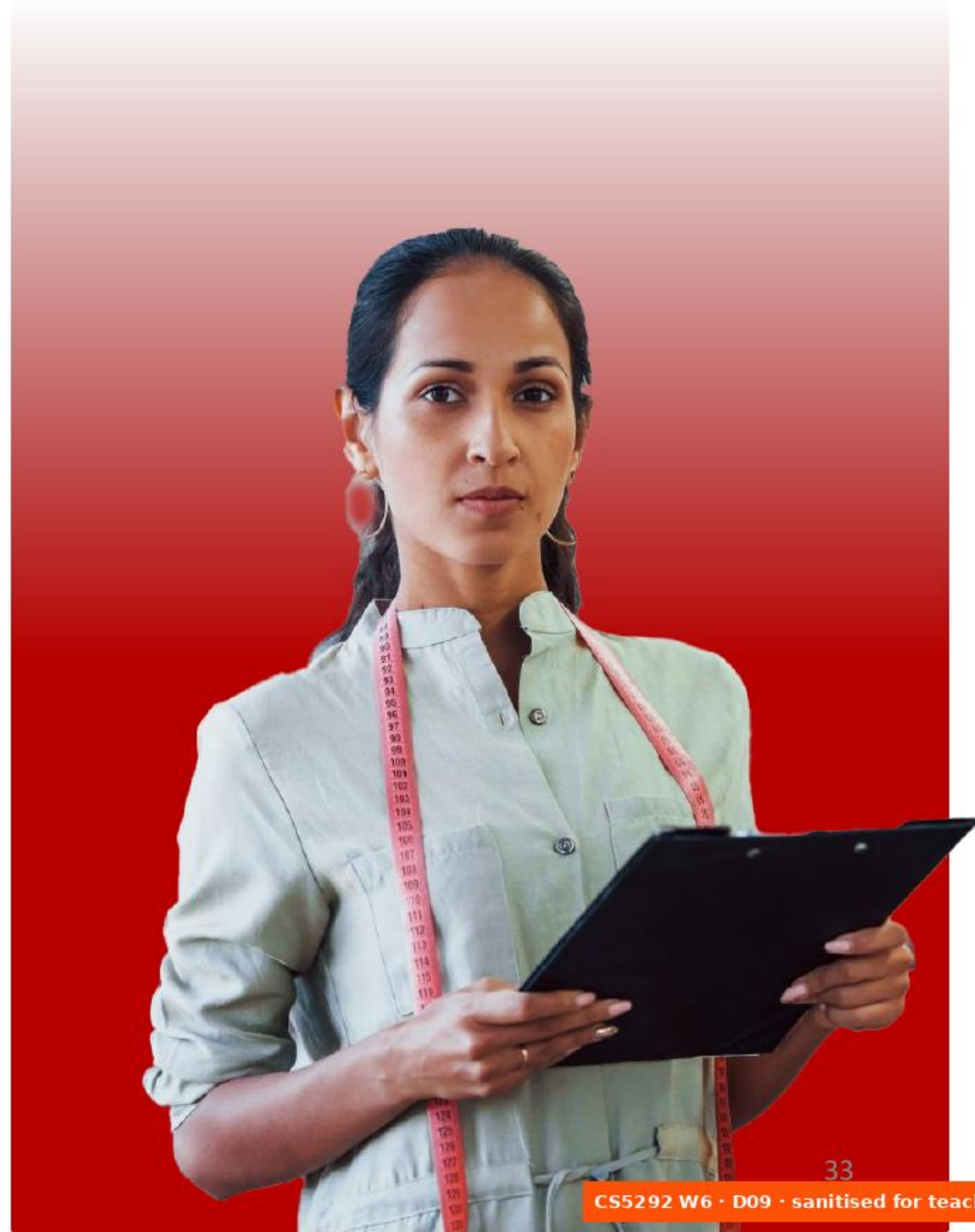
Current



Projection

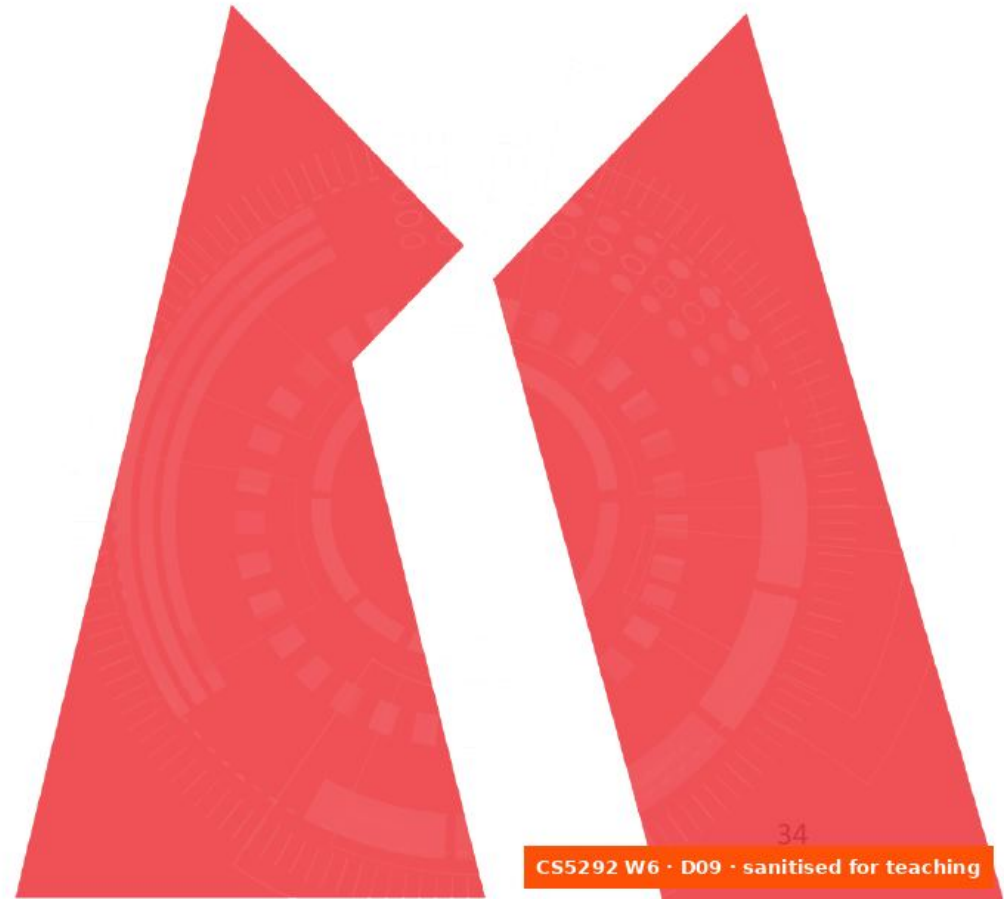


Open Discussion and Q&A



XYZ | XYZ Only

APPENDIX



XYZ | XYZ Only

Pre-read

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
1.	Risk of an attack by a cyber criminal due to lack of employee awareness.	Include phishing simulation tracker with victim out of total users Reduction Plan <10% click rate - Likely <5% click rate - Possible <3% click rate - Unlikely
2.	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices	Reduction Plan - (end devices 88%, servers 75%) - Almost Certain (end devices 86%, servers 82%) - Likely (end devices 95%, servers 90%) - Possible (end devices 100%, servers 100%) - Unlikely
3.	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices	Develop list of devices other than Workstations and Servers -> list and vendor patch release status
4.	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZ Sub-B USA / Sub-C	List of non-governed XYZ entities-> compliance level for security (Endpoint security, Email security, Internet security, Application security, Network Security) List of critical vendors->compliance level Self Assessment to be provided Self assessment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
5.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
6.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely
7.	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack	List of critical vendors->compliance level Self Assessment to be provided Self assesment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
8.	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server/Laptop /API Connection	A-% of devices deployed through intune B-% of local admin accounts detected C-% of browserware detected in CS IT hygiene Almost certain (A <80%, B<10%, C>300) Likely (A<90%, B<5%, C<300) Possible (A<95%, B<1%, C<100) Unlikely (A=100%, B=0, C<50)
9.	Risk of a cyber security incident as a result of Shadow IT	
10.	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.	List of domain servers, firewall baseline configuration < 80% compliance - Almost certain <85% compliance - Likely <95% compliance - Possible 100% compliance - Unlikely
11.	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy	A-% of devices enrolled through auto pilot B- % of devices enrolled through Intune C- Device lost case wipe average time Almost certain (A <80%, B<20%, C<5 days) Likely (A<90%, B<5%, C<3 days) Possible (A<95%, B<5%, C<2 days) Unlikely (A=100%, B=0, C<

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
12.	Risk of a Cyber Security Incident as a result of a malware infection	A-Non-Deployment of CrowdStrike for XYZ assets B-Coverage of mailboxes through Mimecast A< 50 endpoints, B<95% - Almost certain A<30 endpoints, B<98% - Likely A<20 endpoints - Possible 100% compliant on CS, B<99.5 - Unlikely
13.	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or nation state cyber criminals /cyber terrorists targeting XYZ Holdings	Number of threat intel incidents detected (numbers to be defined after setting up SOC radar process)
14.	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZ Technology Services.	

End of Pre-Read

Thank You

